

NOVAC INSURANCE

Customer KYC & Onboarding Platform

Product Requirements Document (PRD) & Detailed Design Document (DDD)
India-Regulated Insurance KYC | IRDAI / PMLA / CKYC / DPDP Compliant
Technology Stack: Node.js (Backend) + React.js (Frontend)

Attribute	Detail
Document Version	1.0 (Draft for Review)
Date	27 July 2026
Prepared By	Senior Full-Stack Development Team
Audience	Product, Engineering, Compliance, InfoSec, QA, IRDAI Audit Liaison
Classification	Internal - Confidential
Status	Pending sign-off (Product, Compliance, Security, Architecture)

Table of Contents

PART A - PRODUCT REQUIREMENTS DOCUMENT

1. Executive Summary
2. Regulatory Context and Drivers
3. Goals, Non-Goals and Scope
4. Personas and Actors
5. KYC Journeys Supported
6. User Stories and Acceptance Criteria
7. Functional Requirements
8. Non-Functional Requirements
9. Regulatory Compliance Traceability Matrix
10. Success Metrics (KPIs)
11. Release Plan
12. Risks, Assumptions and Dependencies

PART B - DETAILED DESIGN DOCUMENT

13. Solution Architecture Overview
14. Technology Stack
15. Frontend Design (React.js)
16. Backend Microservices Design (Node.js)
17. API Specification
18. Data Model
19. Key Sequence Flows
20. External Integrations
21. Security and Data Protection Design
22. Audit, Logging and Data Retention
23. Error Handling and Resilience
24. Deployment and DevOps
25. Testing Strategy
26. Observability
27. Glossary

PART A

Product Requirements Document

1. Executive Summary

Novac Insurance requires a unified, digital-first Know Your Customer (KYC) platform to onboard and periodically re-verify policyholders across life, health and general insurance lines in full compliance with Indian regulations. Since 1 January 2023, IRDAI has mandated KYC for all new insurance policies irrespective of premium amount, and insurers are classified as reporting entities under the Prevention of Money Laundering Act (PMLA), 2002. This document defines the product requirements (Part A) and the detailed technical design (Part B) for a KYC platform built on Node.js microservices and a React.js frontend.

The platform will support Aadhaar OTP-based e-KYC, Aadhaar Offline Paperless XML, DigiLocker document fetch, Central KYC Registry (CKYC) search and download via CERSAI, PAN verification, Officially Valid Document (OVD) upload with OCR and maker-checker review, and Video-Based Identification Process (V-CIP) for assisted journeys. It will file new and updated KYC records with CKYC, screen customers against sanctions and PEP watchlists, maintain a tamper-evident audit trail, and honour consent and data-protection obligations under the Digital Personal Data Protection (DPDP) Act, 2023 and the Aadhaar Act, 2016.

Target outcomes are a straight-through processing (STP) rate above 85% for digital journeys, median KYC completion time under 3 minutes for Aadhaar OTP e-KYC, zero critical audit findings, and full CKYC filing within regulatory timelines.

2. Regulatory Context and Drivers

The platform must be demonstrably compliant with the following framework. Compliance is a first-class product requirement, not an afterthought; every functional requirement in Section 7 traces to at least one of these obligations (see Section 9).

Regulation / Guideline	Obligation Relevant to This Product
IRDAI Master Guidelines on AML/CFT, 2022 (as amended)	Customer due diligence (CDD) before policy issuance; risk-based classification (low/medium/high); enhanced due diligence (EDD) for high-risk and PEP customers; ongoing monitoring; appointment-of-Principal-Officer workflows; suspicious transaction reporting support (STR to FIU-IND).
IRDAI circular on mandatory KYC (effective 01-Jan-2023)	KYC mandatory for all new policies across life, general and health, for any premium amount; permitted modes include Aadhaar e-KYC, CKYC, DigiLocker, OVD and video identification.
PMLA, 2002 and PML (Maintenance of Records) Rules, 2005	Identity verification using OVDs; capture and upload of KYC records to CKYC Registry; record retention for at least 5 years after the business relationship ends; beneficial-owner identification for legal entities.
CERSAI CKYC Registry operating guidelines	Search CKYC by ID/KIN before creating new records; download existing records with customer authorisation; upload new/updated records in the prescribed CKYC template (electronic file formats, photograph, signature, document images) within prescribed timelines.
Aadhaar Act, 2016 and UIDAI regulations (incl. Aadhaar and Other Laws (Amendment) Act, 2019)	Voluntary Aadhaar-based e-KYC with informed consent; use only via licensed KUA/Sub-KUA and ASA channels; storage of Aadhaar numbers only in an Aadhaar Data Vault as reference keys; display/store only masked Aadhaar (last 4 digits); no denial of service for Aadhaar refusal.
DPDP Act, 2023	Free, specific, informed, unconditional and unambiguous consent with clear notice; purpose limitation; data-principal rights (access, correction, erasure subject to retention laws); breach notification; consent-manager readiness.
IRDAI V-CIP / video identification norms	Live, geotagged, officer-assisted or assisted-AI video capture within India; liveness checks; PAN/Aadhaar OVD display and match; audit-quality recording retention.
Income-tax Act, s.139A / CBDT rules	PAN mandatory where premium thresholds apply; PAN name-match validation against the issuing database (Protean/NSDL e-Gov PAN verification).

Regulation / Guideline	Obligation Relevant to This Product
UNSC / MHA sanctions obligations	Screening of proposers, insured, nominees and beneficial owners against UNSCR consolidated lists and domestic banned-entity lists; freeze-and-report workflow on true matches.

3. Goals, Non-Goals and Scope

3.1 Goals

G1 - Provide a single KYC platform consumed by all Novac distribution channels: customer self-service portal, agent/branch assisted portal, bancassurance partner APIs, and mobile apps. G2 - Achieve high straight-through processing with automated verification (Aadhaar e-KYC, CKYC pull, PAN check, face match) and route only exceptions to manual maker-checker review. G3 - Be audit-ready at all times: every consent, verification call, decision and document is versioned, timestamped and attributable. G4 - Complete CKYC search-before-create and CKYC upload for every approved KYC within regulatory timelines. G5 - Support periodic re-KYC driven by risk category (high risk every 2 years, medium every 8, low every 10, per prevailing AML guidelines) with automated customer outreach.

3.2 Non-Goals (Phase 1)

Underwriting decisions, premium computation and policy administration remain in existing core systems; this platform emits KYC outcomes to them. Financial transaction monitoring (ongoing STR analytics) is out of scope beyond exposing KYC risk data to the AML monitoring system. NRI/foreign-national journeys using passports with overseas address proofs are deferred to Phase 2. Aadhaar biometric (fingerprint/iris) e-KYC at branch devices is Phase 2.

3.3 In-Scope Summary

Area	Included in Phase 1
Customer types	Resident individuals; sole proprietorships; companies/LLPs/partnerships/trusts (entity KYC with beneficial-owner capture)
KYC modes	Aadhaar OTP e-KYC; Aadhaar Offline Paperless XML; DigiLocker; CKYC search & download; PAN + OVD upload with OCR; V-CIP (assisted video)
Verification	PAN verification, Aadhaar demographic match, face match (photo vs OVD), liveness, name/DOB fuzzy matching, pincode/address validation, sanctions & PEP screening
Compliance ops	Maker-checker review queue, EDD workflow, risk scoring, CKYC filing, re-KYC scheduling, audit trail, regulatory MIS reports
Channels	Responsive React web app (customer + agent + ops), REST APIs for partners, webhook callbacks to core policy admin

4. Personas and Actors

Persona	Description and Primary Needs
Proposer / Policyholder (self-service)	Buys a policy online; wants fastest possible KYC (Aadhaar OTP or DigiLocker) on mobile; needs clear consent language in English + regional languages; expects instant confirmation.
Agent / POSP / Branch RM (assisted)	Onboards customers in the field or branch; needs a resumable assisted journey, document capture via phone camera, V-CIP scheduling, and visibility of application status.

Persona	Description and Primary Needs
KYC Operations Maker	Reviews exception cases (OCR mismatch, blurry documents, borderline face match); needs a queue with SLA timers, side-by-side document viewer, and structured reject/return reasons.
KYC Operations Checker / Compliance Officer	Approves or rejects maker-reviewed cases; handles EDD and PEP/sanctions escalations; needs four-eyes enforcement and immutable decision logs.
Principal Officer (AML)	Accountable to FIU-IND and IRDAI; needs risk dashboards, screening-hit review, STR-support extracts and CKYC filing status.
Partner System (API consumer)	Bancassurance/aggregator platforms initiating KYC via API; need idempotent APIs, webhooks and sandbox.
Internal Systems	Policy Admin System (consumes KYC outcome), CRM, Data Warehouse, AML transaction-monitoring system.
Auditor / IRDAI Inspector	Read-only evidence access: consent artefacts, verification responses, decision history, retention proofs.

5. KYC Journeys Supported

5.1 Journey Matrix

#	Journey	Ident Proof	Verification Backbone	Target STP
J1	Aadhaar OTP e-KYC	Aadhaar (masked)	UIDAI e-KYC via KUA/ASA; demographic + photo returned by UIDAI	Yes - fully automated
J2	Aadhaar Offline Paperless (XML/QR)	Aadhaar offline XML	Share-code-protected XML signature validation; demographic + photo from XML	Yes
J3	DigiLocker	Aadhaar/PAN/DL via DigiLocker	OAuth consent; issued-document fetch; issuer signature validation	Yes
J4	CKYC Pull	14-digit KIN or PAN/Aadhaar-last-4 + auth factor	CERSAI search & download; customer authorisation; record freshness check	Yes
J5	PAN + OVD Upload	PAN + one OVD (Passport, DL, Voter ID, NREGA card, NPR letter)	PAN verification + OCR + face match + maker-checker	Partial - manual review common
J6	V-CIP (Video KYC)	PAN + Aadhaar (offline XML or OTP) shown on video	Live geotagged video, liveness, officer concurrence, recording retained	Assisted
J7	Entity KYC	CIN/LLPIN/GSTIN + constitution docs	MCA/GST validation, authorised-signatory KYC (J1-J6), UBO declaration & screening	Partial

5.2 Journey Principles

Every journey begins with purpose-specific consent capture and ends with one of four terminal states: APPROVED, REJECTED, EXPIRED or WITHDRAWN. A customer may switch modes mid-journey (e.g., Aadhaar OTP fails thrice, fall back to DigiLocker) without losing captured data. CKYC search-before-create runs silently in the background for every journey so duplicate CKYC records are never created. Aadhaar-based journeys are always presented as one option among several, never as the only path, honouring the voluntary-use principle.

6. User Stories and Acceptance Criteria

ID	User Story	Key Acceptance Criteria
US-01	As a proposer, I can complete KYC using Aadhaar OTP so that my policy is issued instantly.	Consent screen shown before Aadhaar entry; only last 4 digits ever displayed after entry; OTP resend max 3 times; UIDAI response auto-fills name, DOB, gender, address, photo; e-KYC completes in under 3 minutes at p50; failure falls back to alternate modes.
US-02	As a proposer, I can refuse Aadhaar and still finish KYC with PAN + OVD.	Aadhaar step is skippable; PAN verified online with name match score >= threshold; OVD front/back capture with quality checks (blur, glare, edge detection); selfie face-matched to OVD photo.
US-03	As an agent, I can start KYC on my device and hand off to the customer's phone via link/QR.	Session handoff token valid 30 minutes; agent sees live status; customer performs consent + selfie on own device; audit records both actors.
US-04	As a KYC maker, I review exceptions in a queue ordered by SLA.	Side-by-side viewer (document, extracted fields, verification scores); mandatory reason codes on return/reject; cannot approve own escalations.
US-05	As a checker, I approve/reject with four-eyes control.	Checker must differ from maker; PEP/sanction hits require checker + Principal Officer signoff; all decisions immutable with actor, timestamp, IP.
US-06	As a compliance officer, I can prove any KYC to an auditor in under 5 minutes.	One-click evidence bundle: consent artefact, API request/response hashes, documents, decision trail, CKYC acknowledgement - exportable as PDF/ZIP.
US-07	As the system, I file every approved KYC to CKYC.	New records uploaded in CERSAI template within regulatory timeline; KIN stored on success; failures alert ops with retry queue; updates filed on re-KYC.
US-08	As a customer, I receive re-KYC reminders and can complete online.	Reminders at T-60/T-30/T-7 days by SMS/email/WhatsApp; expired KYC flags policy servicing per business rules; re-KYC reuses any still-valid artefacts.
US-09	As a data principal, I can view and download my KYC data and consent history.	DPDP self-service page lists consents with timestamps; grievance/correction request workflow with tracked SLA.

7. Functional Requirements

7.1 Consent and Notice (FR-CON)

ID	Requirement	Priority
FR-CON-01	Display DPDP-compliant notice (purpose, data items, retention, rights, grievance contact) in English and at least Hindi + Tamil before any data capture; store notice version shown.	P0
FR-CON-02	Capture explicit, per-purpose consent (KYC verification, CKYC upload, Aadhaar e-KYC where chosen, communication) with timestamp, IP, device fingerprint and checkbox-state hash.	P0
FR-CON-03	Aadhaar consent must be a distinct artefact quoting UIDAI-prescribed language; declining Aadhaar must not block other modes.	P0
FR-CON-04	Support consent withdrawal requests with downstream effect assessment (retention laws override erasure where applicable, with reasoned response to the data principal).	P1

7.2 Identity Capture and Verification (FR-VER)

ID	Requirement	Priority
FR-VER-01	Aadhaar OTP e-KYC via licensed KUA/Sub-KUA over ASA: initiate, OTP verify, parse KYC XML, store photo and demographics; store Aadhaar number only as vault reference token; render masked (XXXX-XXXX-1234).	P0
FR-VER-02	Aadhaar Offline XML: accept ZIP + share code; validate UIDAI digital signature; reject files older than a configurable freshness window (default 3 days).	P0
FR-VER-03	DigiLocker OAuth 2.0 flow; fetch issued Aadhaar/PAN/DL; validate issuer signature; map to canonical customer model.	P0
FR-VER-04	Online PAN verification (Protean e-Gov API): status must be Existing & Valid; name-match score computed with configurable threshold (default 80, fuzzy token match); Aadhaar-PAN linkage status captured where returned.	P0
FR-VER-05	OVD upload: JPEG/PNG/PDF up to 10 MB; client-side quality checks; server-side OCR extraction of name, DOB, document number, address; extraction confidence surfaced to review.	P0
FR-VER-06	Face match: selfie vs OVD/Aadhaar photo, active or passive liveness; scores stored; below-threshold routed to manual review, never auto-rejected solely on biometrics.	P0
FR-VER-07	V-CIP: scheduled or on-demand video call; geolocation captured and verified within India; random question prompts; live PAN display and OCR; officer disposition (concur/reject) recorded; full recording encrypted and retained.	P0
FR-VER-08	CKYC search (by PAN/Aadhaar-ref/KIN) before every new record creation; on hit and customer authorisation, download record and pre-fill; capture record freshness and trigger update flow when stale.	P0
FR-VER-09	Entity KYC: CIN/LLPIN validation, GSTIN validation, constitution document capture, authorised-signatory individual KYC, beneficial-owner identification per PML Rules thresholds (e.g., >10% ownership for companies) with declaration form.	P1

7.3 Screening and Risk (FR-RSK)

ID	Requirement	Priority
FR-RSK-01	Screen every proposer, insured, nominee, authorised signatory and UBO against UNSC consolidated lists, domestic banned lists and a licensed PEP/adverse-media dataset at onboarding and on list updates (delta screening).	P0

ID	Requirement	Priority
FR-RSK-02	Fuzzy matching with transliteration support; hit adjudication workflow (true match / false positive) with mandatory narrative; true sanctions match freezes onboarding and alerts Principal Officer.	P0
FR-RSK-03	Risk engine assigns Low/Medium/High from configurable factors (product, premium band, occupation, geography, PEP status, channel); High triggers EDD checklist (source-of-funds/wealth, senior-management approval).	P0
FR-RSK-04	Re-KYC scheduler by risk category with configurable periodicities and multi-channel reminders.	P1

7.4 Operations and Filing (FR-OPS)

ID	Requirement	Priority
FR-OPS-01	Maker-checker queues with SLA timers, skill-based routing, bulk assignment, and reason-code taxonomies for return/reject.	P0
FR-OPS-02	CKYC filing: generate CERSAI-template files (data + image annexures), submit, reconcile acknowledgements, persist KIN, retry with exponential backoff, and expose filing MIS.	P0
FR-OPS-03	Outcome publication: webhook + event to Policy Admin with kyCId, status, risk band, KIN, and validity date; idempotent redelivery.	P0
FR-OPS-04	Regulatory MIS: daily/weekly dashboards - volumes by mode, STP%, TAT percentiles, pendency ageing, screening hits, CKYC filing status, re-KYC due lists; CSV/PDF export.	P1
FR-OPS-05	Evidence bundle export per application (US-06).	P0

8. Non-Functional Requirements

Category	Requirement
Performance	p95 API latency <= 800 ms for platform APIs (excluding third-party wait); Aadhaar OTP round trip p95 <= 5 s subject to UIDAI; OCR <= 8 s per document p95; support 50 KYC initiations/second sustained, 150/s burst.
Availability	99.9% monthly for customer-facing services; graceful degradation when a single verifier (e.g., PAN API) is down - queue-and-continue where journey permits.
Scalability	Horizontally scalable stateless Node.js services; queue-based asynchronous verification; 5 million KYC records year-1 design capacity.
Security	TLS 1.3 in transit; AES-256-GCM at rest; Aadhaar Data Vault with HSM-backed keys; field-level encryption for PII; OWASP ASVS L2; annual VAPT; secrets in a managed vault, never in code.
Privacy	Data minimisation; masked rendering of Aadhaar/PAN in all UI and logs; role-based unmasking with justification capture; PII scrubbing in application logs.
Data residency	All PII, documents, video recordings and backups stored in Indian regions only.
Retention	KYC records and audit trails retained minimum 5 years after end of business relationship (PMLA); V-CIP recordings per IRDAI norms; legal-hold override supported.
Auditability	Append-only audit store; hash-chained entries; clock-synced (NTP) timestamps; audit read APIs for inspectors.
Accessibility & UX	WCAG 2.1 AA; responsive down to 360 px; vernacular support (EN/HI/TA at launch); low-bandwidth mode for assisted field journeys.
Compatibility	Evergreen Chrome/Edge/Firefox/Safari; Android 9+/iOS 14+ webviews for embedded partner flows.
DR/BCP	RPO <= 15 min, RTO <= 2 h; cross-zone active-active, cross-region warm DR within India.

9. Regulatory Compliance Traceability Matrix

Obligation	Satisfied By
KYC before policy issuance (IRDAI)	Journeys J1-J7; FR-VER-01..09; outcome gate FR-OPS-03
Aadhaar voluntary use, masked storage (Aadhaar Act / UIDAI)	FR-CON-03, FR-VER-01/02; Aadhaar Data Vault (DDD s21.2)
CKYC search, download, upload (PML Rules / CERSAI)	FR-VER-08, FR-OPS-02; ckyc-connector service (DDD s16)
Record retention 5 years (PMLA)	NFR Retention; archival design (DDD s22.3)
Sanctions/PEP screening (UNSC/IRDAI AML)	FR-RSK-01/02; aml-screening service
Risk-based CDD and EDD (IRDAI AML)	FR-RSK-03; EDD checklist workflow
V-CIP norms	FR-VER-07; video service design (DDD s16, s19.3)
DPDP consent, notice, rights	FR-CON-01..04; consent service; US-09
PAN verification (IT Act)	FR-VER-04; Protean integration (DDD s20)

10. Success Metrics (KPIs)

KPI	Target (6 months post-GA)
Straight-through processing rate (digital journeys J1-J4)	>= 85%
Median end-to-end completion time, Aadhaar OTP journey	<= 3 minutes
KYC drop-off rate (started vs terminal state)	<= 15%
Manual review TAT (maker + checker)	p90 <= 4 working hours
CKYC filing within timeline	100% (zero backlog > timeline)
False-positive rate on screening after tuning	<= 5% of alerts
Critical audit/VAPT findings open > 30 days	0
Platform availability	>= 99.9% monthly

11. Release Plan

Phase	Scope	Indicative Timeline
Phase 0 - Foundations	Environments, CI/CD, security baseline, consent service, customer/application data model, audit store	Weeks 1-6
Phase 1a - Digital STP	J1 Aadhaar OTP, J2 Offline XML, J4 CKYC pull, PAN verification, screening, outcome webhooks, ops console (read-only)	Weeks 7-16
Phase 1b - Assisted & Review	J5 OVD+OCR+face match, maker-checker, J3 DigiLocker, CKYC upload filing, MIS	Weeks 17-24
Phase 1c - V-CIP & Re-KYC	J6 video KYC, re-KYC scheduler, evidence bundles, DPDP self-service	Weeks 25-32
Phase 2	Entity KYC full depth, NRI journeys, biometric e-KYC, consent-manager integration	Post-GA

12. Risks, Assumptions and Dependencies

Type	Item	Mitigation / Note
Risk	UIDAI/CERSAI/Protean sandbox onboarding delays licensing-dependent journeys	Start empanelment (KUA/Sub-KUA via ASA, CERSAI registration) in Phase 0; build against recorded stubs; feature-flag per verifier
Risk	Third-party API instability inflates drop-offs	Circuit breakers, mode fallback UX, queue-and-resume, verifier health on status page
Risk	Regulatory change mid-build (thresholds, templates)	Config-driven rules engine; CKYC template versioning; compliance review gate each release
Risk	Face-match bias / false rejects	Human review on low scores; periodic model evaluation across demographics; never auto-reject on biometrics alone
Assumption	Novac holds/obtains Sub-KUA status via an ASA partner and CERSAI reporting-entity registration	Named compliance owner; tracked as programme milestone
Dependency	Policy Admin System consumes webhook contract v1	Contract-first schema shared Week 4; consumer-driven contract tests
Dependency	Licensed screening dataset (sanctions/PEP) procurement	Vendor selection by Week 8; abstraction layer so vendor is swappable

PART B

Detailed Design Document

13. Solution Architecture Overview

The platform is a set of stateless Node.js microservices behind an API gateway, with a React.js single-page application served via CDN. Services communicate synchronously over REST/gRPC for request paths and asynchronously over Kafka for verification pipelines, filings and notifications. PostgreSQL is the system of record; Redis provides session, OTP-attempt and rate-limit state; object storage (S3-compatible, India region) holds documents and V-CIP recordings with server-side encryption; the Aadhaar Data Vault is an isolated service + HSM enclave reachable only from the verification service over mTLS.

13.1 Logical Components

Layer	Components
Experience	React SPA (customer, agent, ops consoles as role-gated modules); partner REST API; webhook dispatcher
Edge	WAF + CDN; API Gateway (authN via OIDC/JWT, rate limiting, request signing for partners, schema validation)
Domain services (Node.js)	kyc-orchestrator; consent-service; document-service; verification-service; ckyc-connector; aml-screening; risk-engine; vcip-service; review-workflow; notification-service; audit-service; reporting-service
Async backbone	Kafka topics: kyc.events, verification.requests, verification.results, ckyc.filing, screening.delta, notifications.out, audit.stream
Data	PostgreSQL 16 (primary + read replicas); Redis 7; S3-compatible object store; OpenSearch (ops search + MIS); Aadhaar Data Vault (HSM)
Cross-cutting	Vault-based secrets; OpenTelemetry tracing; centralised structured logging with PII scrubbers; feature-flag service

13.2 Architecture Principles

P1 - Orchestration over choreography for the KYC journey: kyc-orchestrator owns the application state machine (DRAFT, CONSENTED, IN_VERIFICATION, PENDING_REVIEW, PENDING_EDD, APPROVED, REJECTED, EXPIRED, WITHDRAWN) so that journey logic lives in one place. P2 - Every external verifier sits behind an adapter with a circuit breaker, timeout budget and recorded-response test double. P3 - PII is encrypted at field level with per-tenant data keys; Aadhaar never leaves the vault boundary in clear form. P4 - All state transitions and third-party exchanges emit audit events before the response returns (write-ahead audit). P5 - Idempotency keys on all mutating APIs; consumers may safely retry.

14. Technology Stack

Concern	Choice	Rationale
Backend runtime	Node.js 20 LTS, TypeScript 5	Team skill alignment; strong async I/O fit for integration-heavy workload; LTS support window
API framework	NestJS (Express adapter)	Modular DI, guards/interceptors for auth + audit, OpenAPI generation, testability
Frontend	React 18 + TypeScript, Vite	Mandated stack; fast HMR builds; mature ecosystem
State/data fetching	Redux Toolkit + RTK Query	Predictable journey state; cache and retry semantics for verification polling
UI kit	MUI v6 + custom Novac theme	WCAG-friendly components; speed of delivery
Forms/validation	React Hook Form + Zod (shared schemas with backend)	Single source of validation truth across FE/BE

Concern	Choice	Rationale
DB & ORM	PostgreSQL 16, Prisma	Relational integrity for compliance data; type-safe queries; auditable migrations
Messaging	Apache Kafka	Ordered, replayable verification and filing pipelines
Cache/session	Redis 7	OTP attempt counters, rate limits, resumable-journey session store
Object storage	S3-compatible (India region), SSE-KMS	Documents and V-CIP recordings with lifecycle policies
OCR/Face/Liveness	Pluggable licensed SDK/API behind verification-service adapters	Vendor-swappable; avoids lock-in; on-soil processing mandated contractually
AuthN/AuthZ	OIDC (Keycloak), JWT access tokens, RBAC + ABAC policies (OPA)	Central identity for staff, customers, partners; fine-grained unmasking rules
Infra	Docker, Kubernetes (managed, Indian region), Helm, Terraform	Reproducible environments; autoscaling
CI/CD	GitHub Actions -> Argo CD (GitOps)	Signed images, progressive delivery, audit of deploys
Observability	OpenTelemetry, Prometheus/Grafana, Loki/OpenSearch, Sentry	Tracing across verifier calls; SLO alerting

15. Frontend Design (React.js)

15.1 Application Structure

A single mono-repo React application with three role-gated shells sharing a design system: Customer (self-service), Agent (assisted), and Ops (maker/checker/compliance). Code is organised feature-first:

Path	Contents
apps/web/src/features/consent	NoticeViewer, ConsentForm, LanguageSwitcher; consent artefact submission
apps/web/src/features/journey	JourneyRouter (state-machine driven), ModeSelector, ProgressTracker, ResumeSession
apps/web/src/features/aadhaar	AadhaarOtpForm (masked input), OtpEntry, OfflineXmlUpload (zip + share code)
apps/web/src/features/digilocker	OAuth redirect handler, DocumentPicker
apps/web/src/features/documents	CameraCapture (getUserMedia), QualityHints (blur/glare), CropPreview, UploadProgress
apps/web/src/features/selfie	LivenessPrompt, SelfieCapture, RetryCoach
apps/web/src/features/vcip	SlotPicker, WebRTC VideoRoom, GeoPermission, OfficerPromptPanel (ops side)
apps/web/src/features/review (ops)	QueueGrid, CaseWorkbench (split-pane doc viewer + extracted fields + scores), DecisionBar, ReasonCodePicker
apps/web/src/features/mis (ops)	Dashboards, exports
packages/ui	Novac design system: themed MUI components, masked-field primitives (AadhaarMask, PanMask)
packages/schemas	Zod schemas shared with backend (journey payloads, API contracts)

15.2 Key Frontend Behaviours

Journey resume: journey state is server-authoritative; the SPA hydrates from GET /applications/:id and never trusts local storage for PII (only a resume token is kept). Masking: Aadhaar and PAN inputs use masked components; full values are posted once over TLS and never echoed back - all subsequent renders receive masked values from the API. Camera capture performs client-side checks (resolution ≥ 1280 px on long edge, blur variance threshold, glare heuristic) before upload to reduce review load. Accessibility: all steps keyboard-navigable; ARIA live regions announce verification progress; vernacular strings via i18next with EN/Hi/TA bundles. Offline resilience for agents: captured images queue in memory with explicit retry; no PII persisted to IndexedDB. Security: strict CSP, no third-party analytics on PII screens, screenshot-deterrent watermarking on ops document viewer (user ID + timestamp overlay).

16. Backend Microservices Design (Node.js)

Service	Responsibility	Key Interfaces
kyc-orchestrator	Owns Application aggregate + state machine; enforces journey rules, mode fallback, SLA timers; publishes domain events	REST: applications CRUD/actions; Kafka: kyc.events
consent-service	Notice versioning, consent artefact creation/verification, withdrawal workflow (DPDP)	REST: consents; immutable artefact store
verification-service	Adapters: UIDAI e-KYC (via ASA), offline-XML validator, PAN (Protean), OCR, face/liveness; normalises results to VerificationResult	Kafka: verification.requests/results; mTLS to Aadhaar vault
ckyc-connector	CERSAI search/download; template file generation (data + images); upload; ack reconciliation; KIN persistence	REST internal; Kafka: ckyc.filing; SFTP/API to CERSAI
aml-screening	List ingestion (UNSC/domestic/vendor PEP), fuzzy matching, delta re-screening, hit adjudication API	REST: screenings, hits; Kafka: screening.delta
risk-engine	Config-driven scoring (JSON rule sets, versioned); outputs risk band + EDD checklist	REST: risk evaluations
vcip-service	WebRTC signalling, room lifecycle, geofence validation, recording pipeline to object store, officer disposition capture	WebSocket + REST; Kafka events
review-workflow	Maker-checker queues, assignment, four-eyes enforcement, reason codes, escalation to Principal Officer	REST: queues, cases, decisions
document-service	Pre-signed uploads, AV scan, EXIF strip, format normalisation, retention/lifecycle, evidence-bundle assembly	REST + S3 events
audit-service	Append-only hash-chained audit log; inspector read APIs; export	Kafka: audit.stream consumer; REST read
notification-service	SMS/email/WhatsApp templates (DLT-registered), re-KYC campaigns	Kafka: notifications.out
reporting-service	MIS aggregates to OpenSearch; scheduled regulatory extracts	REST + exports

Each service is a NestJS application with: request-scoped correlation IDs; Zod-validated DTOs; Prisma repositories; an outbox table pattern so DB writes and Kafka publishes are atomic; health/readiness probes; and per-verifier circuit breakers (opossum) with timeout budgets (UIDAI 30 s, PAN 10 s, OCR 20 s, CERSAI 60 s).

17. API Specification

All APIs are versioned under /api/v1, JSON over HTTPS, JWT-bearer authenticated, and accept an Idempotency-Key header on POST. Representative endpoints:

Method & Path	Purpose	Notes
POST /api/v1/applications	Create KYC application (channel, customerType, productRef)	Returns applicationId + resumeToken; 201
GET /api/v1/applications/{id}	Fetch application state + masked data for hydration	Field-level masking by caller role
POST /api/v1/applications/{id}/consents	Submit consent artefact (noticeVersion, purposes[], locale, uiHash)	409 if notice version stale
POST /api/v1/applications/{id}/aadhaar/otp:initiate	Start UIDAI OTP (aadhaarNumber posted once)	Rate-limited 3/30 min; returns txnRef only
POST /api/v1/applications/{id}/aadhaar/otp:verify	Verify OTP; triggers e-KYC fetch	On success returns masked demographics
POST /api/v1/applications/{id}/aadhaar/offline-xml	Upload XML zip + shareCode	Signature + freshness validation
POST /api/v1/applications/{id}/documents	Request pre-signed upload (docType, side)	Client uploads direct to store; AV + OCR async
POST /api/v1/applications/{id}/selfie	Submit selfie + liveness payload	Face-match job enqueued
POST /api/v1/applications/{id}/pan:verify	Verify PAN + name match	Cached 24 h per PAN+name hash
POST /api/v1/applications/{id}/ckyc:search	Search CKYC registry	Returns match candidates (masked)
POST /api/v1/applications/{id}/ckyc:download	Download CKYC record with customer authorisation	Pre-fills application
POST /api/v1/applications/{id}/vcip/sessions	Create/schedule video session	Returns room token
POST /api/v1/applications/{id}/submit	Move to verification/review pipeline	State-machine guarded
GET /api/v1/review/queues/{queue}/cases	Ops: list cases with SLA	RBAC: maker/checker scopes
POST /api/v1/review/cases/{id}/decision	Approve/return/reject with reason codes	Four-eyes enforced server-side
GET /api/v1/applications/{id}/evidence-bundle	Compliance export (ZIP/PDF)	Audit-logged access
POST /api/v1/webhooks/subscriptions	Partner webhook registration	HMAC-signed deliveries, retries with backoff

Error model: RFC 7807 problem+json with stable error codes (e.g., KYC-4101 OTP_EXPIRED, KYC-4210 PAN_NAME_MISMATCH, KYC-5301 VERIFIER_UNAVAILABLE). Webhook event types: kyc.approved, kyc.rejected, kyc.expiring, ckyc.filed, screening.hit.raised.

18. Data Model

PostgreSQL is the system of record. PII columns marked (E) are field-level encrypted (AES-256-GCM, envelope keys via KMS); (M) indicates only masked derivatives are readable by application roles. Core tables:

Table	Key Columns	Notes
customers	id (uuid), full_name (E), dob (E), gender, mobile (E,M), email (E,M), pan_token (M), aadhaar_vault_ref, ckyc_kin, risk_band, status	aadhaar_vault_ref is an opaque vault token; raw Aadhaar never stored here
kyc_applications	id, customer_id, channel, mode, state, product_ref, sla_due_at, valid_until, created_by, version	Optimistic locking via version; state matches orchestrator machine
consent_records	id, application_id, notice_version, purposes[], locale, ip, device_fp_hash, ui_hash, granted_at, withdrawn_at	Immutable rows; withdrawal creates linked row
kyc_documents	id, application_id, doc_type, side, storage_key, sha256, av_status, ocr_json (E), quality_scores, uploaded_by	Object-store key only; lifecycle policy tag
verification_results	id, application_id, verifier (UIDAI/PAN/OCR/FACE/LIVENESS/CKYC), request_hash, response_hash, outcome, score, raw_ref (E), latency_ms, created_at	Raw payloads in encrypted blob store; hashes support evidence integrity
ckyc_filings	id, application_id, direction (SEARCH/DOWNLOAD/UPLOAD/UPDATE), batch_ref, template_version, status, kin, ack_ref, attempts, last_error	Reconciliation source of truth
screening_checks	id, subject_type (PROPOSER/NOMINEE/UBO...), subject_ref, list_version, engine_score, status	Delta re-screen keyed by list_version
screening_hits	id, check_id, list_entry_ref, match_score, disposition (TRUE/FALSE_POSITIVE/PENDING), adjudicated_by, narrative, escalated	True hits lock application
review_cases	id, application_id, queue, maker_id, checker_id, state, reason_codes[], sla_due_at	DB constraint: checker_id <> maker_id
risk_evaluations	id, application_id, ruleset_version, factors_json, band, edd_required	Ruleset versioned for auditability
vcip_sessions	id, application_id, officer_id, geo_lat, geo_lng, geo_verified, recording_key, liveness_score, disposition, started_at, ended_at	Recording retained per policy
audit_events	seq (bigserial), occurred_at, actor_type, actor_id, action, entity, entity_id, payload_hash, prev_hash, chain_hash	Append-only; hash chain per day-partition; no UPDATE/DELETE grants
webhook_deliveries	id, subscription_id, event_type, payload_hash, status, attempts, next_retry_at	At-least-once with idempotency key

Partitioning: audit_events and verification_results partitioned monthly; documents lifecycle to infrequent-access tier after 18 months; hard retention hold enforced until 5 years after relationship-end date propagated from Policy Admin.

19. Key Sequence Flows

19.1 Aadhaar OTP e-KYC (J1)

Step	Interaction
1	SPA posts consent artefact (incl. UIDAI consent text version) to consent-service; orchestrator moves DRAFT -> CONSENTED.

Step	Interaction
2	SPA posts Aadhaar number once to otp:initiate; verification-service forwards to vault, which calls UIDAI via ASA and returns txnRef; Aadhaar number is tokenised in the vault and discarded from service memory.
3	Customer enters OTP; otp:verify -> vault -> UIDAI e-KYC; signed KYC XML decrypted inside vault; demographics + photo returned to verification-service with vault_ref.
4	verification-service emits VerificationResult(UIDAI, PASS); orchestrator auto-runs PAN verify (if PAN provided), face match (selfie vs UIDAI photo), CKYC search, and screening in parallel via Kafka.
5	risk-engine evaluates; low risk + all green -> state APPROVED; ckyc-connector enqueues upload (or update if KIN exists); webhook kyc.approved to Policy Admin; audit events at every step.
6	Any amber result (face score below threshold, name mismatch) -> PENDING_REVIEW with a maker case; any sanctions true-hit path locks to PENDING_EDD/Principal Officer.

19.2 CKYC Search and Download (J4)

Step	Interaction
1	With consent, SPA posts identifiers (PAN or KIN) to ckyc:search; ckyc-connector queries CERSAI and returns masked candidates.
2	Customer authorises download (authentication factor per CERSAI rules, e.g., OTP to CKYC-registered mobile where applicable); connector downloads record + images.
3	Record freshness evaluated; if address/photo stale or attributes changed, orchestrator branches into an update capture flow; else data pre-fills and journey proceeds to screening/risk as in 19.1 step 4-5.
4	On approval with changes, ckyc-connector files an UPDATE record; acknowledgement reconciled into ckyc_filings.

19.3 V-CIP (J6)

Step	Interaction
1	Customer picks slot (or on-demand); vcip-service creates room; browser permissions requested for camera/mic/geolocation; session blocked if geolocation outside India or unavailable.
2	Officer joins from ops console; identity script read; random prompts issued (e.g., head turn, read displayed digits) for liveness; PAN shown live to camera and OCR-matched; Aadhaar offline-XML demographics compared.
3	Face match runs between live frames and OVD/Aadhaar photo; scores displayed to officer; officer records concur/reject with remarks.
4	Recording is encrypted, checksummed and written to object store; session metadata + disposition persisted; orchestrator resumes standard screening/risk/approval pipeline.

20. External Integrations

Integration	Protocol / Pattern	Design Notes
UIDAI e-KYC (via ASA/KUA)	Signed XML over HTTPS through ASA; vault-mediated	eKYC licence keys in HSM; response signature verification; UIDAI error-code mapping to friendly retries; strict 3-attempt OTP policy
Aadhaar Offline XML	Local validation	UIDAI public-key signature check; share-code decrypt; freshness window config
DigiLocker	OAuth 2.0 + REST	Issued-doc list, file fetch, issuer signature validation; scope minimisation

Integration	Protocol / Pattern	Design Notes
CERSAI CKYC	API/SFTP batch per CERSAI spec	Template version registry; image spec conformance (size/dpi); nightly reconciliation of acks; retry with dead-letter + ops alert
Protean (NSDL e-Gov) PAN	REST	Bulk + single verify; response cached 24 h; name-match algorithm documented for audit
Sanctions/PEP vendor + UNSC lists	Scheduled ingestion (API/CSV)	List versioning; delta screening fan-out on update; vendor abstraction interface
OCR / Face / Liveness vendor	REST/SDK, data-processing addendum	India-region processing; no vendor-side retention; scores + model version stored
SMS/Email/WhatsApp	DLT-registered SMS gateway; ESP; WhatsApp BSP	Template governance; consent-aware sending
Policy Admin System	Webhooks + Kafka bridge	HMAC signatures, replay protection, at-least-once with consumer idempotency

21. Security and Data Protection Design

21.1 Identity, Access and Segregation

Staff and partner identities live in Keycloak; customers authenticate via OTP-bound session tokens scoped to a single application. RBAC roles (customer, agent, maker, checker, compliance, principal-officer, auditor-readonly, sysadmin) are combined with OPA-evaluated ABAC policies for unmasking: viewing an unmasked PAN requires role + case assignment + reason selection, and every unmask event is audited. Production access follows just-in-time elevation with approval and session recording for administrative actors.

21.2 Aadhaar Data Vault

Aadhaar numbers exist in exactly one place: the vault, an isolated service with its own database and HSM-protected keys, network-reachable only from verification-service over mTLS with SPIFFE identities. All other systems hold an opaque vault reference token. The vault exposes only tokenise, e-KYC-proxy and masked-render operations; it never returns a full Aadhaar number to any caller. Vault access logs stream to the audit chain, and key ceremonies follow dual-control procedures.

21.3 Data Protection Controls

Control	Implementation
Encryption in transit	TLS 1.3 external; mTLS service-to-service; HSTS; certificate rotation automated
Encryption at rest	Storage-level AES-256 plus field-level envelope encryption for PII columns; per-data-class keys in KMS; annual key rotation
Masking	Masked-by-default API serialisers; UI masked components; log scrubbers reject Aadhaar/PAN regex patterns at the transport layer
Application security	OWASP ASVS L2 checklist in CI; dependency scanning (SCA), SAST, secret scanning; DAST pre-release; annual external VAPT and CERT-In empanelled audit
Anti-abuse	Rate limits per device/IP/mobile; OTP attempt lockouts; bot detection on public endpoints; upload AV scanning and content-type sniffing
DPDP alignment	Purpose-tagged data inventory; consent linkage on every processing job; data-principal request workflows (access/correction) with SLA tracking; breach-response runbook with notification templates

22. Audit, Logging and Data Retention

22.1 Audit Chain

audit-service consumes audit.stream and writes append-only rows where each row's chain_hash = SHA-256(prev_hash || payload_hash || occurred_at). Daily anchors (the last chain_hash of the day) are exported to write-once storage, making tampering evident. Inspectors get a read-only console filtered by application, actor or period, and evidence bundles embed the relevant chain segment with verification instructions.

22.2 Logging

Structured JSON logs with correlation and application IDs; PII scrubbing middleware runs before transport; verifier payloads are never logged - only hashes and outcome codes. Log retention: 13 months hot/warm for operations, security-relevant events forwarded to the SIEM.

22.3 Retention and Disposal

KYC records, consent artefacts, verification evidence and audit segments are retained for a minimum of 5 years after the business relationship ends, driven by a relationship-end event from Policy Admin; V-CIP recordings follow the same schedule unless a longer legal hold applies. Disposal is a scheduled, logged, dual-approved job producing certificates of destruction; DPDP erasure requests are honoured only where they do not conflict with these statutory retention duties, with a reasoned response recorded either way.

23. Error Handling and Resilience

Scenario	Behaviour
UIDAI/ASA outage	Circuit opens after threshold failures; UI offers DigiLocker/OVD fallback automatically; queued retries for in-flight e-KYC not attempted (customer-present flow), clean restart instead
CERSAI filing failure	Filing is asynchronous: exponential backoff (1m/5m/30m/2h/12h), then dead-letter with ops alert; application approval is not blocked, but MIS tracks unfilled backlog against timeline
OCR/face vendor degraded	Secondary vendor adapter (if licensed) or route-to-manual-review flag; SLO-based auto-toggle via feature flags
Duplicate submissions	Idempotency keys + unique constraints; orchestrator state machine rejects illegal transitions with 409
Partial verification results	Aggregation window with timeout; missing results mark the case amber for review rather than blocking indefinitely
Webhook consumer down	At-least-once retries for 24 h with jitter; replay API for consumers; delivery ledger visible to partner

24. Deployment and DevOps

Environments: dev, QA, UAT (with verifier sandboxes/stubs), pre-prod (production parity, masked data), prod - all in Indian regions. Kubernetes deployments use Helm charts per service; images are signed (cosign) and admission-controlled. GitOps via Argo CD promotes through environments on tagged releases; database migrations run as gated jobs with automatic backout plans. Progressive delivery: canary 5% -> 25% -> 100% with automated rollback on SLO burn. Secrets from Vault via CSI driver; no secrets in env files or images. Infrastructure is Terraform-managed with drift detection; production changes require change-management approval linked to the release ticket.

25. Testing Strategy

Layer	Approach
Unit	Jest + ts-jest across services and React components; Zod schema round-trip tests; >= 80% branch coverage gate on domain modules
Contract	Pact consumer-driven contracts between SPA/partners and APIs, and between orchestrator and Policy Admin webhooks
Integration	Testcontainers (Postgres, Kafka, Redis); recorded verifier stubs (UIDAI/CERSAI/PAN) with failure-mode fixtures (timeouts, malformed, error codes)
E2E	Playwright journeys J1-J6 including camera/OTP mocks; accessibility assertions (axe) on every step
Security	SAST/SCA/secret scans per PR; DAST pre-release; annual VAPT; masking-regression suite asserting no unmasked PII in any API/log fixture
Performance	k6 load tests to 150 KYC/s burst; soak tests 24 h; verifier-latency chaos injection
Compliance UAT	Compliance-owned test book mapped to Section 9 matrix; sign-off is a release gate

26. Observability

Golden signals per service (latency, traffic, errors, saturation) with SLOs: availability 99.9%, p95 latency budgets per endpoint, verification pipeline lag < 60 s. Distributed traces span SPA -> gateway -> orchestrator -> verifier adapters, with third-party wait time attributed separately. Business telemetry dashboards: funnel conversion per journey, STP rate, drop-off by step, verifier health, CKYC filing backlog, review queue ageing, screening alert rates. Alerting routes: engineering on-call (PagerDuty) for SLO burns; compliance-ops channel for filing backlog and true-hit events.

27. Glossary

Term	Meaning
ASA / KUA / Sub-KUA	Authentication Service Agency / KYC User Agency - UIDAI-licensed roles through which e-KYC is performed
CKYC / KIN	Central KYC Registry operated by CERSAI; KIN is the 14-digit KYC Identifier Number
CERSAI	Central Registry of Securitisation Asset Reconstruction and Security Interest of India - operates CKYC
OVD	Officially Valid Document: passport, driving licence, Aadhaar, voter ID, NREGA job card, NPR letter
V-CIP	Video-based Customer Identification Process
EDD / CDD	Enhanced / Customer Due Diligence
PEP	Politically Exposed Person
UBO	Ultimate Beneficial Owner
FIU-IND	Financial Intelligence Unit - India (receives STRs)
DPDP Act	Digital Personal Data Protection Act, 2023
STP	Straight-Through Processing (no manual touch)
STR	Suspicious Transaction Report

Document Sign-off: This document requires approval from Product Owner, Chief Compliance Officer / Principal Officer, CISO, and Head of Engineering before build commencement. Regulatory references should be re-validated against the latest IRDAI/CERSAI/UIDAI circulars at the start of each phase, and the traceability matrix in Section 9 updated accordingly.